



Report ZAP do projeto final

Site: <http://localhost>

Generated on domingo, 10 mai. 2026 15:31:26

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
Alto	0
Médio	1
Baixo	3
Informational	1

Insights

Level	Reason	Site	Description	Statistic
Baixo	Aviso		ZAP errors logged - see the zap. log file for details	1
Baixo	Aviso		ZAP warnings logged - see the zap. log file for details	53
Info	Informational	http://clients2.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://clients2.google.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	http://clients2.google.com	Percentage of endpoints with method GET	100 %
Info	Informational	http://clients2.google.com	Count of total endpoints	1

Info	Informational	http://clients2.google.com	Percentage of slow responses	33 %
Info	Informational	http://localhost	Percentage of responses with status code 2xx	5 %
Info	Informational	http://localhost	Percentage of responses with status code 3xx	45 %
Info	Informational	http://localhost	Percentage of responses with status code 4xx	48 %
Info	Informational	http://localhost	Percentage of endpoints with content type image /x-icon	14 %
Info	Informational	http://localhost	Percentage of endpoints with content type text /html	85 %
Info	Informational	http://localhost	Percentage of endpoints with method GET	85 %
Info	Informational	http://localhost	Percentage of endpoints with method POST	14 %
Info	Informational	http://localhost	Count of total endpoints	7
Info	Informational	https://accounts.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://accounts.google.com	Percentage of endpoints with content type application /binary	100 %
			Percentage of	

Info	Informational	https://accounts.google.com	endpoints with method POST	100 %
Info	Informational	https://accounts.google.com	Count of total endpoints	1
Info	Informational	https://accounts.google.com	Percentage of slow responses	50 %
Info	Informational	https://android.clients.google.com	Percentage of responses with status code 2xx	54 %
Info	Informational	https://android.clients.google.com	Percentage of responses with status code 3xx	43 %
Info	Informational	https://android.clients.google.com	Percentage of responses with status code 4xx	2 %
Info	Informational	https://android.clients.google.com	Percentage of endpoints with content type application /x-protobuf	33 %
Info	Informational	https://android.clients.google.com	Percentage of endpoints with content type text /plain	66 %
Info	Informational	https://android.clients.google.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://android.clients.google.com	Count of total endpoints	3
Info	Informational	https://android.clients.google.com	Percentage of slow responses	100 %
Info	Informational	https://chromewebstore.googleapis.com	Percentage of responses with status code 2xx	100 %
			Percentage of endpoints	

Info	Informational	https://chromewebstore.googleapis.com	with content type application /x-protobuf	100 %
Info	Informational	https://chromewebstore.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://chromewebstore.googleapis.com	Count of total endpoints	1
Info	Informational	https://chromewebstore.googleapis.com	Percentage of slow responses	75 %
Info	Informational	https://content-autofill.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://content-autofill.googleapis.com	Percentage of endpoints with content type application /x-protobuf	87 %
Info	Informational	https://content-autofill.googleapis.com	Percentage of endpoints with content type text /plain	12 %
Info	Informational	https://content-autofill.googleapis.com	Percentage of endpoints with method GET	12 %
Info	Informational	https://content-autofill.googleapis.com	Percentage of endpoints with method POST	87 %
Info	Informational	https://content-autofill.googleapis.com	Count of total endpoints	8
Info	Informational	https://content-autofill.googleapis.com	Percentage of slow responses	70 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of responses with status code 2xx	100 %

Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with content type application/x-protobuf	50 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with content type text/html	50 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with method GET	50 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with method POST	50 %
Info	Informational	https://optimizationguide-pa.googleapis.com	Count of total endpoints	2
Info	Informational	https://optimizationguide-pa.googleapis.com	Percentage of slow responses	81 %
Info	Informational	https://passwordsleakcheck-pa.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://passwordsleakcheck-pa.googleapis.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informational	https://passwordsleakcheck-pa.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://passwordsleakcheck-pa.googleapis.com	Count of total endpoints	5
Info	Informational	https://passwordsleakcheck-pa.googleapis.com	Percentage of slow responses	100 %
Info	Informational		Percentage of	100 %

		https://update.googleapis.com	responses with status code 2xx	
Info	Informational	https://update.googleapis.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://update.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://update.googleapis.com	Count of total endpoints	4
Info	Informational	https://update.googleapis.com	Percentage of slow responses	70 %
Info	Informational	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.google.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informational	https://www.google.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://www.google.com	Count of total endpoints	1
Info	Informational	https://www.google.com	Percentage of slow responses	100 %
Info	Informational	https://www.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.googleapis.com	Percentage of endpoints with content type application/json	100 %

Info	Informational	https://www.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://www.googleapis.com	Count of total endpoints	1
Info	Informational	https://www.googleapis.com	Percentage of slow responses	100 %

Alertas

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Médio	1
In Page Banner Information Leak	Baixo	1
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Baixo	1
Server Leaks Version Information via "Server" HTTP Response Header Field	Baixo	Systemic
Session Management Response Identified	Informational	3

Alert Detail

Médio	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost/projeto_final.*
Node Name	http://localhost/projeto_final.*
Método	GET
Atacar	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/

	https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Baixo	In Page Banner Information Leak
Description	The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.
URL	http://localhost/projeto_final/.*
Node Name	http://localhost/projeto_final/.*
Método	GET
Atacar	
Evidence	Apache/2.4.58
Other Info	There is a chance that the highlight in the finding is on a value in the headers, versus the actual matched string in the response body.
Instances	1
Solution	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/
CWE Id	497
WASC Id	13
Plugin Id	10009

Baixo	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://localhost/projeto_final/
Node Name	http://localhost/projeto_final/
Método	GET
Atacar	
Evidence	X-Powered-By: PHP/8.2.12
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework

	https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Baixo	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://localhost/projeto_final/
Node Name	http://localhost/projeto_final/
Método	GET
Atacar	
Evidence	Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
Other Info	
URL	http://localhost/projeto_final/
Node Name	http://localhost/projeto_final/
Método	GET
Atacar	
Evidence	Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
Other Info	
URL	http://localhost/projeto_final/admin.php
Node Name	http://localhost/projeto_final/admin.php
Método	GET
Atacar	
Evidence	Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
Other Info	
URL	http://localhost/projeto_final/login.php
Node Name	http://localhost/projeto_final/login.php
Método	GET
Atacar	
Evidence	Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
Other Info	
URL	http://localhost/projeto_final/autentica.php
Node Name	http://localhost/projeto_final/autentica.php (codigo,csrf_token,logi,senh)
Método	POST
Atacar	

Evidence	Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://localhost/projeto_final/login.php
Node Name	http://localhost/projeto_final/login.php
Método	GET
Atacar	
Evidence	PHPSESSID
Other Info	cookie:PHPSESSID
URL	http://localhost/projeto_final/autentica.php
Node Name	http://localhost/projeto_final/autentica.php ()(codigo,csrf_token,logi,senh)
Método	POST
Atacar	
Evidence	PHPSESSID
Other Info	cookie:PHPSESSID
URL	http://localhost/projeto_final/autentica.php
Node Name	http://localhost/projeto_final/autentica.php ()(codigo,csrf_token,logi,senh)
Método	POST
Atacar	
Evidence	PHPSESSID
Other Info	cookie:PHPSESSID
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	

Plugin Id	10112
-----------	-----------------------